Third-Party Vendor Risk Assessment Standard

Document ID: COMP-VRM-2026-07 | **Owner:** Legal & Risk Governance | **Date:** 08 March 2026

Vendor Tiers

Vendors processing customer data are Tier 1 (High Risk). Vendors providing corporate software without customer data access are Tier 2 (Moderate Risk). Operational suppliers are Tier 3 (Low Risk).

Due Diligence Requirements

Tier 1 vendors must furnish an unmodified SOC 2 Type II report completed within the preceding 12 months, along with an active ISO 27001 certificate and recent external penetration test summary.

Contractual Safeguards

All vendor agreements handling company intellectual property or personal data must execute the standard Data Processing Addendum (DPA) containing standard contractual clauses (SCCs).

Re-certification Frequency

High-risk Tier 1 vendors undergo mandatory security and financial reassessments every 12 months. Failure to remediate identified security findings within 60 days results in termination.